Comparação de Comportamento: Prepared Statements e SQL Injection

1. Comparação de Comportamento (Payloads)

Payload	Versão A (sem prepared)	Versão B (com prepared)
1. Lisboa	Busca normal: Retorna corretamente apenas os voos com destino 'Lisboa'.	Busca normal: Retorna corretamente apenas os voos com destino 'Lisboa'.
2. '	Erro de Banco: A aplicação quebra e exibe um erro de sintaxe do MySQL (SQLSTATE[42000]), pois a aspa simples injetada desbalanceia a estrutura do comando original.	Array vazio: A consulta é executada com sucesso, mas não retorna nada, pois o banco procura literalmente por um destino chamado '.
3. ' OR '1'='1	Bypass de Filtro: Retorna todos os voos cadastrados no banco de dados. A injeção transforma a cláusula WHERE em uma condição que é sempre verdadeira.	Array vazio: A consulta é executada com sucesso e procura literalmente por uma cidade de destino chamada ' OR '1'='1, não retornando nada.
4. x' UNION SELECT id, email, senha_hash, 4, 5 FROM usuarios --	Vazamento de Dados: Os dados da tabela de usuários (id, email e senhas) são renderizados na tela de listagem de voos, misturados aos resultados da consulta original.	Array vazio: O banco de dados entende o payload inteiro apenas como uma string de texto longa e sem sentido para a coluna destino. Nenhum dado vaza.

2. Respostas Teóricas

1. Por que a versão B se comporta diferente com o mesmo texto de entrada?

Porque os Prepared Statements pré-compilam a estrutura da consulta SQL no banco de dados antes da inserção dos valores. Isso força o banco a tratar qualquer texto de entrada estritamente como um dado literal (uma string), impossibilitando que o texto injetado pelo usuário altere a lógica estrutural da consulta.

2. O que o banco recebe como comando e o que recebe como dado em cada versão?

Na Versão A, o banco recebe uma única string vulnerável onde código SQL e dados estão concatenados e misturados (tudo é interpretado como comando). Na Versão B, o banco recebe a instrução em duas etapas distintas: primeiro apenas a estrutura do comando (SELECT ... WHERE destino = ?), e em seguida o pacote isolado contendo apenas o dado.

3. Se só a versão A existisse em produção, qual seria o pior dano do payload 4?

O impacto máximo seria o comprometimento total da confidencialidade do sistema através do vazamento de informações sensíveis. Atacantes teriam acesso aos e-mails e hashes de senhas de todos os usuários, permitindo quebrar as credenciais offline, realizar account takeover (roubo de contas) ou invadir perfis administrativos.